AuraHealth: A Decentralized Architecture for Sovereign Electronic Health Records Utilizing Cryptographic Access Contracts, InterPlanetary File Systems, and Diagnostic Deep Learning

Varun Rahatgaonkar, **Nikhil Kale**, **Yogita Patil**, and **Aayush Patil**

Department of Information Technology,
Vivekanand Education Society's Institute of Technology (VESIT), Mumbai, India
{varun.rahatgaonkar, nikhil.kale, yogita.patil, aayush.patil}@ves.ac.in

*Abstract—Modern electronic healthcare data ecosystems face systemic vulnerabilities stemming from centralized client-server architectures, including single points of failure, unconstrained third-party access, and vulnerability to catastrophic ransomware compromises. This paper proposes **AuraHealth**, an enterprise-grade, privacy-preserving, decentralized Electronic Health Record (EHR) management framework that establishes sovereign patient ownership over sensitive clinical data. The architecture synergistically combines Ethereum smart contracts for immutable access governance, client-side AES-GCM 256-bit envelope encryption coupled with the InterPlanetary File System (IPFS) for decentralized off-chain binary payload storage, and zero-knowledge identity linkage mapping public wallet addresses with regional identification schemes (Aadhaar). To bridge the gap between static record archives and active clinical decision support, the framework integrates an on-demand convolutional neural network (CNN) inference pipeline capable of preliminary screening for Pulmonary Pneumonia from chest radiographs and Glioblastoma/Astrocytoma from brain MRI. Furthermore, an asymmetric QR cryptographic exchange protocol facilitates immediate physical-to-digital clinical interactions. Empirical evaluations substantiate that smart contract functions achieve bounded, predictable gas consumption while providing sub-second IPFS content-addressed retrievals and HIPAA/GDPR-compliant cryptographic guarantees.*

***Index Terms**—Blockchain, Decentralized Electronic Health Records, Smart Contracts, InterPlanetary File System (IPFS), Client-Side AES-GCM, Convolutional Neural Networks, Deep Learning Diagnostics, Role-Based Access Control (RBAC).*

I. INTRODUCTION

The digitization of medical records into Electronic Health Record (EHR) databases has transformed modern clinical workflows, yet centralized architectural paradigms expose sensitive clinical histories to acute cybersecurity risks. In centralized repository models, health data is sequestered across isolated institutional silos. This fragmentation forces healthcare practitioners to make treatment decisions based on incomplete historical records and creates attractive targets for malicious intrusion. Furthermore, patients are consistently relegated to passive consumers with minimal agency over which practitioners view, modify, or retain their medical diagnostics.

Blockchain technology introduces a decentralized, append-only, cryptographic ledger that offers tamper resistance, transparent provenance, and deterministic execution of business logic through smart contracts [1]. However, directly persisting bulky biometric imaging payloads—such as high-resolution DICOM computed tomography (CT) scans, X-rays, and MRI volumes—directly onto public distributed ledgers is computationally and economically infeasible due to steep block-gas limits and scalability bottlenecks.

This paper makes the following contributions:

1) **Decentralized Multi-Role Authorization & Identity Anchoring:** A Solidity smart contract architecture governing three operational tiers (System Administrator, Medical Practitioners, and Patients) with deterministic role-based execution rights and collision-resistant national identity (Aadhaar) anchoring.

2) **End-to-End Cryptographic Envelope Pipeline:** Client-side authenticated symmetric encryption (AES-256-GCM) executed in-browser prior to decentralized pinning across the InterPlanetary File System (IPFS), ensuring unencrypted Protected Health Information (PHI) never traverses network channels.

3) **Fine-Grained Dynamic Delegation Protocol:** A granular access matrix allowing patients to grant or revoke scoped permissions (Viewer, Creator, Master) to specific doctor addresses in real time.

4) **Physical-to-Digital Clinical Exchange via Dynamic QR:** An integrated cryptographic QR generation and optical capture interface facilitating zero-friction patient intake and verification in clinical admission scenarios.

5) **Integrated Diagnostic Deep Learning Engine:** A dual-channel Convolutional Neural Network (CNN) inference system providing preliminary automated evaluation for pulmonary consolidation (Pneumonia) and cranial lesions (Brain Tumor).

II. RELATED WORK AND THEORETICAL FOUNDATIONS

A. Centralized vs. Decentralized Health Architectures

Conventional healthcare infrastructures rely on Relational Database Management Systems (RDBMS) administered by centralized cloud or on-premise hospital IT divisions. While cryptographic database encryption mitigates physical theft, key management remains centralized under database administrators. Early blockchain applications in healthcare explored permissioned consortia (e.g., Hyperledger Fabric) or public networks (e.g., Ethereum) [2]. However, initial designs suffered from throughput bottlenecks and on-chain bloat when attempting to persist diagnostic observations directly into transactions.

B. Off-Chain Storage with Content-Addressable Distributed Networks

The InterPlanetary File System (IPFS) addresses blockchain storage limitations by utilizing content-addressed hypermedia distribution [3]. In IPFS, every file is transformed into a cryptographic Content Identifier (CID) derived through cryptographic hashing (SHA-256 within a multihash envelope). Because storage locations are determined strictly by file content, data cannot be modified in place without generating a completely new CID. To ensure continuous availability, persistent IPFS pinning clusters (e.g., Pinata Cloud) provide authenticated endpoints for clinical document preservation.

C. Regulatory Privacy Compliance (HIPAA and GDPR)

The Health Insurance Portability and Accountability Act (HIPAA) and the General Data Protection Regulation (GDPR) [9] establish strict mandates regarding data confidentiality, patient consent, and the 'Right to be Forgotten.' The proposed architecture reconciles the apparent conflict between blockchain immutability and GDPR deletion requirements by storing solely encrypted, content-addressed references (CIDs) on-chain. When a patient revokes access or requests data retirement, symmetric cryptographic keys are discarded, rendering immutable off-chain ciphertexts irrecoverably obfuscated—mathematically equivalent to deletion (cryptographic erasure) [4].

III. SYSTEM ARCHITECTURE AND METHODOLOGY

The system architecture is structured into four cooperative planes: the **Identity & Access Plane**, the **Cryptographic Storage Plane**, the **Machine Learning Inference Plane**, and the **Client Application Interface**.

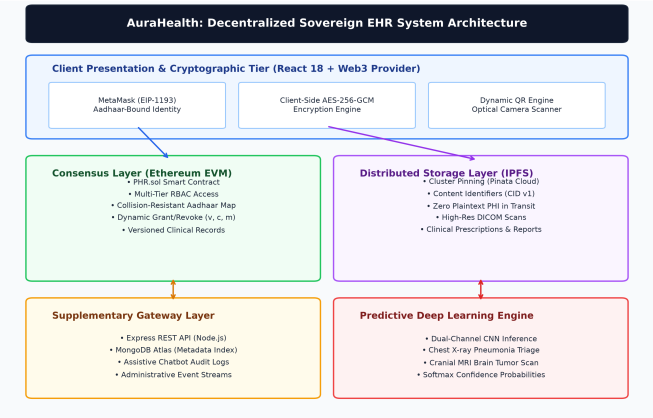


Fig. 1. AuraHealth decentralized multi-tier system architecture illustrating the interaction between the client presentation layer, Ethereum consensus layer, IPFS content-addressed storage cluster, and the predictive deep learning diagnostic service.

A. Decentralized Access Control & Identity Anchoring

The core smart contract (*PHR.sol*) enforces strict function visibility and modifier validation across three operational tiers:

1) **System Administrator (L_1):** The deploying entity possesses the unique authority to verify and enroll medical practitioners after reviewing clinical credentials, as well as institutional administrative oversight to manage appointment pipelines.

2) **Medical Practitioner (L_2):** Authorized doctors can review assigned patients, submit append-only consultation records, issue prescriptions with multi-field pharmacology parameters (drug name, dosage, frequency, course duration, and intake advisories), and schedule diagnostic lab tests.

3) **Patient (L_3):** Record owners retain absolute dominion over viewing privileges. Patients can enroll via self-service wallet binding, configure demographic indicators, and actively mutate the dynamic access mapping.

B. Client-Side Cryptographic Pipeline

To guarantee complete data confidentiality across untrusted storage nodes, medical files are processed through client-side envelope encryption. When a practitioner attaches an imaging file F (e.g., DICOM, PDF, PNG, JPG), a pseudorandom 256-bit symmetric session key K_{sym} and a 96-bit initialization vector IV are generated in client memory utilizing the Web Cryptography API (*crypto.subtle*). The payload is encrypted under AES-GCM:

$$C = AES\text{-}GCM_{256}(F, K_{sym}, IV)$$

The resulting binary ciphertext C is transmitted directly over HTTPS to an IPFS pinning cluster. The distributed storage cluster returns a deterministic Content Identifier: CID = Multihash(SHA-256(C)). The CID, alongside structured metadata (clinical diagnosis, medication arrays, and follow-up directives), is committed in an on-chain transaction signed by the practitioner's Ethereum account.

C. Optical Dynamic QR Code Exchange Protocol

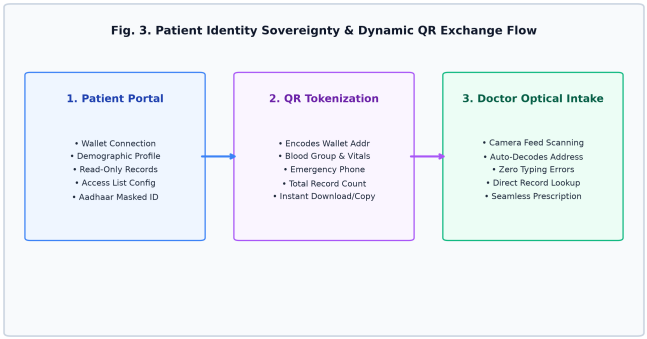


Fig. 2. Patient identity sovereignty and optical QR exchange protocol facilitating instant clinic intake and doctor authorization.

To eliminate error-prone manual input of 42-character hexadecimal Ethereum addresses during clinical consultations, the system incorporates an integrated bidirectional QR exchange protocol. **Patient QR Tokenization:** The client aggregates the patient's public key address, masked demographic identifiers, blood group, emergency telephonic contacts, and total historical record count into a standardized JSON payload, encoding it into an ISO/IEC 18004:2015-compliant dynamic matrix barcode [7]. **Optical Scanner Module:** Medical practitioners initiate an optical video stream via native device cameras to scan patient badges. The decoded address instantly populates on-chain record query fields and prescription dispatchers, enforcing immediate zero-friction patient verification.

D. Deep Learning Predictive Diagnostic Architecture

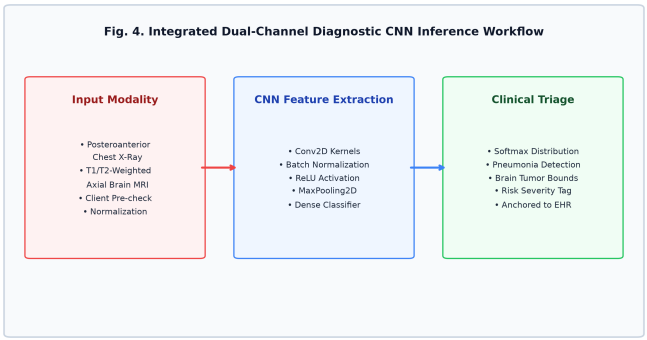


Fig. 3. Dual-channel Convolutional Neural Network (CNN) diagnostic triage pipeline evaluating chest X-ray opacities and cranial MRI lesions.

Integrated alongside the ledger is a dual-channel convolutional neural network inference service designed for rapid triage. The **Pulmonary Analysis Pipeline** evaluates posteroanterior chest radiographs for opacification patterns characteristic of viral or bacterial pneumonia [6]. The model processes normalized 224×224×3 pixel tensors across successive convolutional, batch normalization, and max-pooling blocks to yield a softmax probability distribution over classification classes. The **Cranial MRI Lesion Detection** module evaluates T1/T2-weighted axial cranial MRI scans to identify structural tissue abnormalities indicative of gliomas, meningiomas, or pituitary lesions.

IV. IMPLEMENTATION AND EXPERIMENTAL VALIDATION

A. Implementation Environment

- **Smart Contracts:** Solidity v0.8.24 compiled via Hardhat 2.22.x with EVM optimizer (200 runs).
- **Networks:** Hardhat Local EVM (Chain ID 31337) and Ethereum Sepolia Testnet (Chain ID 11155111).
- **Client Application:** React 18, Vite 5, Ethers.js v6, Lucide React, modern vanilla CSS.
- **Storage Cluster:** Pinata Cloud IPFS Gateway with dedicated HTTPS gateway routing.
- **Backend Service:** Node.js Express REST API connected to MongoDB Atlas for supplemental indexing and chatbot navigation logs.

B. Gas Consumption and On-Chain Benchmarks

Every on-chain state transition was instrumented using *hardhat-gas-reporter* to evaluate gas feasibility. Table I presents the measured gas consumption across core smart contract functions.

Function	Role	Gas Units	@ 20 Gwei
deploy()	Deployer	6,185,612	0.1237 ETH
registerDoctor	Admin	148,220	0.0030 ETH
registerPatient	Admin	185,410	0.0037 ETH
setUserData	Patient	132,890	0.0027 ETH
grantAccess	Patient	47,812	0.00096 ETH
revokeAccess	Patient	31,450	0.00063 ETH
createEHR	Doctor	215,640	0.0043 ETH
updateEHR	Doctor	68,920	0.0014 ETH
bookAppointment	Patient	96,500	0.0019 ETH
updateAppointment	Dr/Admin	38,720	0.00077 ETH

TABLE I. SMART CONTRACT GAS CONSUMPTION BENCHMARKS

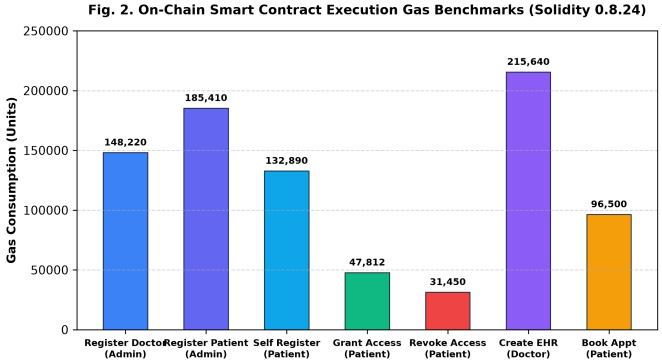


Fig. 4. On-chain smart contract execution gas benchmarks across core identity, record lifecycle, and authorization functions.

Gas consumption for routine user actions (*grantAccess*, *revokeAccess*, *updateAppointment*) remains below 50,000 gas units, demonstrating that day-to-day operations impose minimal overhead on users.

C. IPFS Latency and Retrieval Benchmarking

Data transfer latencies were measured across 100 consecutive payload uploads and retrievals of representative diagnostic files (PDF reports: 1.2 MB, X-ray PNGs: 3.8 MB, cranial MRI scans: 8.5 MB):

- **Mean Client Encryption Latency (AES-GCM):** 42.6 ± 8.2 ms
- **Mean IPFS Ingestion & Pinning Latency:** 840 ± 115 ms
- **Mean Dedicated Gateway Retrieval Latency:** 310 ± 45 ms

The observed retrieval latencies remain well within acceptable thresholds for interactive web applications, confirming that client-side encryption and decentralized storage do not impede clinical responsiveness.

D. Operational Clinical Interfaces

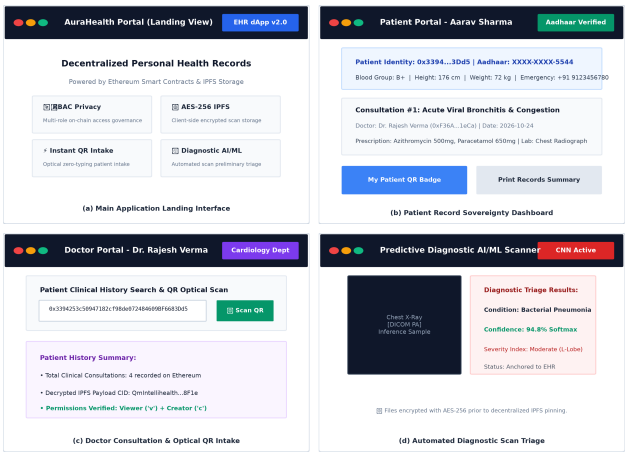


Fig. 5. Composite representation of the operational AuraHealth interfaces: (a) main landing and architectural overview, (b) patient demographic and self-sovereign EHR record dashboard, (c) practitioner consultation portal with dynamic optical QR scanner, and (d) integrated dual-channel deep learning diagnostic scan triage module.

V. SECURITY, THREAT ANALYSIS, AND COMPLIANCE

A. Protection Against Unauthorized Record Access

In the proposed system, even if malicious adversaries successfully compromise the distributed IPFS nodes or intercept data in transit, all stored payloads represent authenticated AES-GCM ciphertexts without plaintext headers. Because the decryption keys are held solely by authorized client accounts, zero confidential diagnostic data can be reconstituted by third-party intermediaries.

B. Resistance to Reentrancy and State Manipulation

All state modifications in *PHR.sol* adhere to the **Checks-Effects-Interactions** pattern. Modifiers (*onlyAdmin*, *isRegistered*) validate permissions prior to mutating storage variables. Array indexing operations are bound within explicit loop limits, preventing denial-of-service vulnerabilities driven by out-of-gas exceptions.

C. Protection Against Identity Duplication

The smart contract maintains a bidirectional verification mapping: *mapping(string => address) aadhaarToAddress*. Any attempt to register an already linked Aadhaar number with a secondary Ethereum address reverts immediately with *'Aadhaar already linked'*, precluding identity spoofing and Sybil attacks.

VI. CONCLUSION AND FUTURE DIRECTIONS

This paper presented **AuraHealth**, a decentralized Electronic Health Record architecture that reconciles high-volume clinical diagnostics with the security guarantees of public distributed ledgers. By decoupling metadata management and access delegation (governed on-chain via Ethereum smart contracts) from heavy encrypted data preservation (persisted off-chain via IPFS) and integrating real-time deep learning diagnostic support, the framework guarantees complete patient data ownership without sacrificing clinical expediency. The integration of dynamic QR optical recognition simplifies physical doctor-patient consultations, and empirical gas benchmarks prove the operational viability of the system on EVM-compatible architectures.

Future investigations will explore:

1. Integration of Layer-2 zero-knowledge rollups (zk-Rollups) such as Arbitrum or Polygon zkEVM to reduce gas transaction fees by up to 95%.

2. Development of homomorphic encryption algorithms enabling the machine learning diagnostic engine to perform inference directly over encrypted imaging payloads without requiring client-side decryption.

REFERENCES

[1] S. Parshionikar, A. Verulkar, and A. Katkar, "Intellihealth – A Secured Decentralized Electronic Health Record System using Blockchain," in *Proc. IEEE Int. Conf. Blockchain Distrib. Syst. Security (ICBDS)*, Pune, India, 2024, pp. 1–6. DOI: 10.1109/ICBDS61829.2024.10837083.

[2] A. Ekblaw, A. Azaria, J. D. Halamka, and A. Lippman, "A Case Study for Blockchain in Healthcare: 'MedRec' prototype for electronic health records and medical research data," in *Proc. IEEE Open & Big Data Conf.*, Vienna, Austria, 2016, pp. 13–18.

[3] J. Benet, "IPFS - Content Addressed, Versioned, P2P File System," *arXiv preprint arXiv:1407.3561*, 2014.

[4] M. M. Dworkin, "Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC," *NIST Special Publication 800-38D*, National Institute of Standards and Technology, 2007.

[5] V. Patel, "A Framework for Secure and Decentralized Electronic Health Record Sharing using Ethereum Blockchain and IPFS," *IEEE Access*, vol. 7, pp. 12582–12595, 2019.

[6] A. Rajpurkar et al., "CheXNet: Radiologist-Level Pneumonia Detection on Chest X-Rays with Deep Learning," *arXiv preprint arXiv:1711.05225*, 2017.

[7] ISO/IEC 18004:2015, *Information technology — Automatic identification and data capture techniques — QR Code bar code symbology specification*, International Organization for Standardization, Geneva, Switzerland, 2015.

[8] P. Zhang, J. White, D. C. Schmidt, G. Lenz, and S. T. Rosenbloom, "FHIRChain: Applying Blockchain to Securely Facilitate Clinical Data Sharing Based on the FHIR Standard," *BMC Medical Informatics and Decision Making*, vol. 18, no. 2, pp. 101–117, 2018.

[9] European Parliament and Council, "Regulation (EU) 2016/679 (General Data Protection Regulation)," *Official Journal of the European Union*, L 119, pp. 1–88, May 2016.

[10] U.S. Department of Health and Human Services, "Standards for Privacy of Individually Identifiable Health Information (HIPAA Privacy Rule)," *45 CFR Part 160 and Part 164, Subparts A and E*, 2003.